BỘ CÔNG AN **CÔNG AN TỈNH QUẢNG NGÃI**	**CỘNG HÒA XÃ HỘI CHỦ NGHĨA VIỆT NAM** **Độc lập - Tự do - Hạnh phúc**
Số: 9050/CAT-ANM V/v cảnh báo và hướng dẫn khắc phục lỗ hổng bảo mật nghiêm trọng tháng 10/2026	*Quảng Ngãi, ngày06 tháng 11 năm 2026*

Kính gửi:
- Ủy ban Mặt trận Tổ quốc Việt Nam tỉnh;
- Văn phòng Tỉnh ủy, Văn phòng UBND tỉnh;
- Văn phòng Đoàn ĐBQH và HĐND tỉnh;
- Các sở, ban ngành và hội đoàn thể tỉnh;
- Bộ Chỉ huy Quân sự tỉnh; Tòa án nhân dân tỉnh;
- Viện Kiểm sát nhân dân tỉnh; Thi hành án dân sự tỉnh;
- Bảo hiểm xã hội tỉnh; Cảng vụ Hàng hải Quảng Ngãi;
- Thống kê tỉnh; Thuế tỉnh Quảng Ngãi;
- Kho bạc Nhà nước khu vực XV;
- Báo và Phát thanh, Truyền hình Quảng Ngãi;
- Các Trường: Đại học Phạm Văn Đồng, Cao đẳng Kon Tum, Cao đẳng Việt Nam - Hàn Quốc - Quảng Ngãi;
- Công ty cổ phần – Tổng Công ty Lọc hóa dầu Việt Nam; Truyền tải điện Quảng Ngãi; Điện lực Quảng Ngãi;
- UBND các xã, phường, Đặc khu Lý Sơn.

Trong tháng 10/2026, qua công tác bảo đảm an ninh mạng, lực lượng An ninh mạng và phòng, chống tội phạm sử dụng công nghệ cao Công an tỉnh đã thực hiện phân tích và tổng hợp đối với **20** lỗ hổng bảo mật nghiêm trọng ảnh hưởng đến hệ thống thông tin trên địa bàn tỉnh *(Tài liệu lưu hành nội bộ)*. Trong đó, có 10 lỗ hổng bảo mật có mức độ nghiêm trọng, 10 lỗ hổng bảo mật có mức độ cao.

1. Các lỗ hổng bảo mật trên hệ điều hành của Microsoft

1.1. Lỗ hổng CVE-2026-96951 – Cho phép vượt qua tính năng bảo mật Shell của Windows

- Đánh giá mức độ nghiêm trọng: Cao; Điểm CVSS: 8.8/10.

- Mô tả: Lỗ hổng tiêm lệnh và vượt qua tính năng bảo mật xảy ra bên trong thành phần Windows Shell của hệ điều hành Microsoft Windows. Tin tặc tạo ra một tệp tin được chỉnh sửa đặc biệt, sau đó gửi tệp tin này cho nạn nhân qua email, tin nhắn tức thời (Instant Message) hoặc các công cụ cộng tác như Microsoft Teams, Slack. Lỗ hổng sẽ bị kích hoạt ngay khi người dùng tương tác. Lỗ hổng

cho phép tệp tin độc hại hoàn toàn vượt qua cơ chế bảo mật Mark of the Web (MOTW) và thực thi mà không hiển thị bất kỳ cảnh báo nguy hiểm nào cho người dùng, từ đó tạo tiền đề để tin tặc thực thi mã độc, đánh cắp thông tin hoặc chiếm quyền kiểm soát hệ thống.

- Phiên bản ảnh hưởng**:** Lỗ hổng ảnh hưởng đến tất cả các phiên bản Microsoft Windows và Windows Server đang được hỗ trợ.

- Khuyến nghị**:** Microsoft thông báo lỗ hổng đã được vá trong đợt phát hành Patch Tuesday tháng 10/2026 (đợt cập nhật kỷ lục với hơn 1.400 lỗi được vá nhờ sự hỗ trợ của AI). Quản trị viên và người dùng cá nhân cần truy cập Windows Update trên thiết bị và tiến hành cài đặt ngay các gói cập nhật tích lũy (Cumulative Updates) mới nhất. Thông tin chi tiết về lỗ hổng: https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-96951.

- Lỗ hổng chưa có PoC công khai.

1.2. Lỗ hổng CVE-2026-108398 - Vượt qua tính năng bảo mật của .NET Framework

- Đánh giá mức độ nghiêm trọng: Cao; Điểm CVSS: 8.8/10.

- Mô tả: Lỗ hổng đường dẫn tìm kiếm không đáng tin cậy (Untrusted Search Path) tồn tại trong Microsoft .NET Framework. Tin tặc có thể khai thác lỗ hổng bằng cách đặt một tệp độc hại vào thư mục tìm kiếm được ứng dụng tin cậy sử dụng, khiến hệ thống tải và thực thi thành phần trái phép. Qua đó, tin tặc có thể vượt qua cơ chế kiểm soát ứng dụng Windows Defender Application Control (WDAC), tạo điều kiện thực thi mã trái phép và có khả năng leo thang đặc quyền trên hệ thống.

- Phiên bản ảnh hưởng: Lỗ hổng ảnh hưởng đến một số phiên bản Microsoft .NET Framework, bao gồm các phiên bản 3.5, 4.6.2, 4.7, 4.7.1, 4.7.2, 4.8 và 4.8.1. Cần đối chiếu phiên bản và số hiệu bản dựng cụ thể với thông báo của Microsoft để xác định chính xác phạm vi ảnh hưởng.

- Khuyến nghị: Microsoft đã phát hành bản cập nhật bảo mật khắc phục lỗ hổng này trong đợt cập nhật ngày 13/10/2026. Quản trị viên hệ thống cần rà soát phiên bản .NET Framework đang sử dụng và triển khai gói cập nhật bảo mật tương ứng theo hướng dẫn của Microsoft. Đồng thời, cần kiểm soát chặt chẽ quyền ghi vào các thư mục chứa ứng dụng và thư mục tìm kiếm thành phần nhằm ngăn chặn việc chèn tệp độc hại. Thông tin chi tiết: https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-108398.

- Lỗ hổng chưa có PoC công khai.

1.3. Lỗ hổng CVE-2026-72987 sử dụng bộ nhớ sau khi đã giải phóng (Use-after-free) trong dịch vụ DNS của hệ điều hành Windows

- Đánh giá mức độ nghiêm trọng: Cao; Điểm CVSS: 8.1/10.

- Mô tả:

+ Lỗ hổng thuộc loại Use After Free (CWE-416) trong dịch vụ Windows DNS. Khi DNS Server tiếp nhận một gói tin, dịch vụ cấp phát một vùng bộ nhớ trên heap để chứa đối tượng xử lý truy vấn đó (gọi là *context object*). Sau khi hoàn tất xử lý, vùng nhớ này được giải phóng (*free*). Lỗ hổng xảy ra do trong một số tình huống xử lý chuỗi gói tin đặc biệt, một luồng xử lý khác trong dịch vụ vẫn giữ con trỏ (*dangling pointer*) trỏ đến vùng nhớ đã được giải phóng, vi phạm nguyên tắc quản lý vòng đời đối tượng. Khi luồng xử lý thứ hai tiếp tục chạy và đọc hoặc ghi dữ liệu thông qua con trỏ cũ, chương trình sẽ thao tác trên vùng nhớ không còn thuộc quyền quản lý của nó.

+ Kẻ tấn công xây dựng một chuỗi gói tin DNS được tính toán kỹ lưỡng và gửi đến dịch vụ DNS đang chạy trên máy chủ mục tiêu. Gói tin đầu tiên kích hoạt việc cấp phát vùng nhớ heap cho đối tượng xử lý truy vấn; gói tin tiếp theo được thiết kế để buộc dịch vụ giải phóng vùng nhớ đó trong khi một luồng xử lý song song vẫn giữ con trỏ trỏ đến vùng nhớ này. Sau khi vùng nhớ được giải phóng, kẻ tấn công gửi thêm các gói tin có kích thước được tính toán phù hợp với vùng nhớ vừa giải phóng, nhằm khiến hệ điều hành tái sử dụng đúng vùng nhớ đó. Các gói tin này mang theo shellcode - đoạn mã mà kẻ tấn công muốn máy chủ thực thi - và ghi dữ liệu vào vùng nhớ vừa được tái sử dụng. Luồng xử lý vẫn giữ địa chỉ vùng nhớ cũ tiếp tục hoạt động và đọc dữ liệu tại địa chỉ đó. Lúc này, chương trình không còn đọc dữ liệu DNS hợp lệ mà có thể đọc phải shellcode của kẻ tấn công và thực thi mã độc với quyền SYSTEM. Khi khai thác thành công, kẻ tấn công có thể kiểm soát hoàn toàn máy chủ bị ảnh hưởng, bao gồm khả năng đánh cắp dữ liệu, triển khai phần mềm độc hại và mở rộng cuộc tấn công sang các hệ thống khác trong mạng. Do có vai trò đặc thù, máy chủ DNS sau khi bị chiếm quyền còn có thể bị lợi dụng để can thiệp vào hệ thống phân giải tên miền, chuyển hướng lưu lượng mạng nội bộ đến máy chủ giả mạo và gây mất kiểm soát hạ tầng mạng của tổ chức mà không cần tấn công từng thiết bị đầu cuối.

- Phiên bản ảnh hưởng: Các hệ điều hành bị ảnh hưởng bao gồm Windows 10 phiên bản 1607 và 1809, cùng các phiên bản Windows Server từ 2012 đến 2025, bao gồm cả bản cài đặt Server Core. Lỗ hổng đặc biệt nguy hiểm đối với các máy chủ đang vận hành dịch vụ DNS, nhất là các máy chủ DNS trong hạ tầng mạng nội bộ của cơ quan, tổ chức.

- Khuyến nghị: Triển khai các bản cập nhật bảo mật chính thức của Microsoft, bao gồm KB5122871, KB5122876, KB5122882, KB5123065, KB5123066 và KB5123099. Các bản cập nhật có thể được tải xuống từ Microsoft Update Catalog hoặc triển khai thông qua Windows Update, Intune hoặc WSUS.

(Liên kết hướng dẫn: https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-72987). Trong thời gian chờ cập nhật, cần hạn chế hoặc chặn các yêu cầu DNS từ bên ngoài bằng Tường lửa Windows hoặc danh sách kiểm soát truy cập mạng (ACL); đồng thời, xem xét tắt vai trò DNS Server trên các máy chủ không thực sự cần vận hành dịch vụ này.

1.4. Lỗ hổng CVE-2026-69688 leo thang đặc quyền trong thành phần Windows Encrypting File System (EFS)

- Đánh giá mức độ nghiêm trọng: Cao; Điểm CVSS: 7.1/10.

- Mô tả:

+ Lỗ hổng xuất phát từ lỗi tràn bộ đệm trên heap (CWE-122 – Heap-based Buffer Overflow) trong quá trình hệ thống mã hóa tệp tin tích hợp sẵn trong Windows (Encrypting File System – EFS) xử lý các thao tác mã hóa qua mạng. EFS cấp phát một vùng nhớ trên heap có kích thước cố định để chứa dữ liệu đầu vào nhưng không kiểm tra đầy đủ xem dữ liệu thực tế có vượt quá dung lượng vùng nhớ được cấp phát hay không. Khi kẻ tấn công gửi dữ liệu lớn hơn kích thước vùng nhớ này, phần dữ liệu vượt quá có thể ghi đè lên các vùng nhớ liền kề trên heap, làm thay đổi các cấu trúc dữ liệu của chương trình, bao gồm cả con trỏ hàm hoặc thông tin kiểm soát luồng thực thi. Điều này có thể dẫn đến thực thi mã trái phép hoặc leo thang đặc quyền, tùy thuộc vào khả năng khai thác cụ thể.

+ Kẻ tấn công cần có tài khoản người dùng thông thường với quyền hạn thấp, không có quyền quản trị hoặc quyền truy cập vào các tài liệu nhạy cảm. Từ tài khoản này, kẻ tấn công gửi một yêu cầu mã hóa EFS được tạo thủ công qua mạng đến máy chủ mục tiêu. Yêu cầu này có thể kích hoạt lỗi tràn bộ đệm trong thành phần xử lý EFS, khiến dữ liệu vượt quá giới hạn ghi đè lên các vùng nhớ liền kề. Nếu khai thác thành công, kẻ tấn công có thể vượt qua các giới hạn quyền hiện có, truy cập tài nguyên trái phép hoặc thực thi mã với đặc quyền cao hơn. Sau khi leo thang đặc quyền thành công, kẻ tấn công có thể truy cập các tệp tin được bảo vệ bằng EFS mà tài khoản ban đầu không được phép truy cập, bao gồm tài liệu mật, khóa mã hóa hoặc thông tin đăng nhập được lưu trữ, tùy thuộc vào quyền đạt được và cơ chế bảo vệ của hệ thống.

- Phiên bản ảnh hưởng: Windows 10 (từ phiên bản 1607 đến 22H2), Windows 11 (từ phiên bản 23H2 đến 26H1) và Windows Server từ phiên bản 2012 đến 2025.

- Khuyến nghị: Triển khai các bản cập nhật KB5122871, KB5122876, KB5122878, KB5122880, KB5122882, KB5123065, KB5123066, KB5123099, KB5124008 và KB5124012 tương ứng với từng phiên bản Windows (liên kết hướng dẫn: https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-69688). Tắt hoặc hạn chế sử dụng EFS trên các máy chủ không có nhu cầu thực

sự nhằm giảm thiểu bề mặt tấn công. Đồng thời, rà soát và tăng cường kiểm soát truy cập mạng đối với các dịch vụ liên quan đến EFS.

1.5. Lỗ hổng CVE-2026-69632 thực thi mã từ xa (RCE) trong bộ phần mềm Microsoft Office

- Đánh giá mức độ nghiêm trọng: Cao; Điểm CVSS: 8.8/10.

- Mô tả:

+ Lỗ hổng thuộc loại Use After Free (CWE-416) trong thành phần xử lý tài liệu của Microsoft Office. Cụ thể, khi một đối tượng nội bộ của Office (có thể liên quan đến các thành phần phân tích cú pháp OLE/OOXML – cơ chế được Office sử dụng để đọc và tái tạo cấu trúc tài liệu từ dữ liệu đầu vào, bao gồm các định dạng như .docx, .xlsx và .pptx) được cấp phát bộ nhớ để xử lý nội dung tài liệu rồi giải phóng, nhưng một luồng xử lý khác vẫn giữ con trỏ trỏ đến đối tượng đó, lỗ hổng có thể xảy ra. Kẻ tấn công có thể lợi dụng tình huống này để kiểm soát dữ liệu được ghi vào vùng nhớ đã giải phóng. Khi Office tiếp tục truy cập vùng nhớ thông qua con trỏ cũ, chương trình có thể xử lý dữ liệu do kẻ tấn công kiểm soát, dẫn đến thực thi mã trái phép.

+ Kẻ tấn công đặt một tệp Office độc hại tại vị trí mạng mà nạn nhân có quyền truy cập, chẳng hạn như thư mục chia sẻ nội bộ, SharePoint hoặc thông qua email chứa liên kết trực tiếp đến tệp được lưu trữ trên OneDrive/SharePoint. Khi nạn nhân mở tệp, Office bắt đầu tải và phân tích cú pháp nội dung, qua đó có thể kích hoạt lỗi Use After Free. Nếu khai thác thành công, mã độc có thể được thực thi với quyền của tài khoản người dùng hiện tại, ngay trong phiên Office đang hoạt động. Kẻ tấn công có thể lợi dụng quyền này để cài đặt phần mềm gián điệp, đánh cắp tài liệu hoặc sử dụng phiên Office đang chạy để mở rộng phạm vi tấn công sang các thư mục mạng khác mà người dùng có quyền truy cập. Trong môi trường cơ quan, tổ chức sử dụng SharePoint/OneDrive làm hạ tầng lưu trữ và chia sẻ tài liệu, một tệp độc hại được đặt tại vị trí phù hợp có thể trở thành nguồn phát tán mã độc đến nhiều người dùng mà không cần gửi email riêng lẻ cho từng người.

- Phiên bản ảnh hưởng**:** Các phiên bản Microsoft Office trên cả Windows và macOS, cụ thể gồm: Microsoft 365 Apps for Enterprise (các bản có số hiệu build thấp hơn 16.0.20326.20138), Microsoft Office 2019 (thấp hơn build 16.0.10417.20207), Microsoft Office LTSC 2021 (thấp hơn build 16.0.14334.20906), Microsoft Office LTSC 2024 (thấp hơn build 16.0.17932.20976). Đối với macOS, các sản phẩm bị ảnh hưởng gồm Office 365 for Mac, Office LTSC for Mac 2021 và Office LTSC for Mac 2024 (các bản có số hiệu build thấp hơn 16.113.26091433).

- Khuyến nghị: Cập nhật các bản vá bảo mật chính thức do Microsoft phát hành theo hướng dẫn tại địa chỉ: https://msrc.microsoft.com/update-

guide/vulnerability/CVE-2026-69632. Cấu hình Group Policy để bật Protected View đối với các tệp có nguồn gốc từ Internet hoặc vị trí mạng không đáng tin cậy; kể cả các tệp được chia sẻ qua SharePoint nội bộ cũng cần được kiểm soát và xác minh trước khi cho phép chỉnh sửa. Rà soát, hạn chế quyền ghi tệp vào các thư mục chia sẻ dùng chung, chỉ cấp quyền cho những người thực sự có nhu cầu, nhằm giảm thiểu nguy cơ kẻ tấn công lợi dụng tài khoản đã bị xâm nhập để phát tán tệp độc hại đến những người dùng khác.

1.6. Lỗ hổng CVE-2026-78505 thực thi mã từ xa (RCE) trong bộ phần mềm Microsoft Office

- Đánh giá mức độ nghiêm trọng: Cao; Điểm CVSS: 8.8/10.

- Mô tả:

+ Mô tả: Lỗ hổng xuất phát từ lỗi tràn bộ đệm trên heap (CWE-122 – Heap-based Buffer Overflow) trong thành phần phân tích cú pháp tài liệu của Microsoft Office khi xử lý nội dung nhận từ mạng. Office cấp phát một vùng nhớ trên heap có kích thước cố định để chứa dữ liệu từ tài liệu nhưng không kiểm tra đầy đủ kích thước dữ liệu thực tế trước khi ghi. Khi kẻ tấn công cung cấp dữ liệu lớn hơn kích thước vùng nhớ được cấp phát, phần dữ liệu vượt quá có thể tràn sang các vùng nhớ liền kề trên heap, ghi đè lên các cấu trúc dữ liệu hoặc thông tin điều khiển của chương trình, từ đó có thể dẫn đến thực thi mã tùy ý trong phiên Office đang hoạt động.

+ Kẻ tấn công có thể gửi email hoặc đặt tệp độc hại vào thư mục mạng dùng chung. Tệp Office được tạo đặc biệt, chứa dữ liệu vượt quá kích thước bộ đệm được cấp phát và có thể được thiết kế để lợi dụng lỗi tràn bộ đệm nhằm thực thi mã độc. Khi người dùng mở tệp, Office tiến hành phân tích cú pháp nội dung, có thể kích hoạt lỗi tràn bộ đệm và dẫn đến thực thi mã trái phép trong phiên Office với quyền của tài khoản người dùng hiện tại. Nếu khai thác thành công, kẻ tấn công có thể thực thi mã tùy ý với quyền của tài khoản đang đăng nhập, cài đặt phần mềm gián điệp, đánh cắp tài liệu trên máy tính hoặc lợi dụng thiết bị làm bàn đạp để tiếp tục tấn công sâu hơn vào mạng nội bộ.

- Phiên bản ảnh hưởng: Lỗ hổng ảnh hưởng đến các phiên bản Microsoft Office trên cả Windows và macOS. Trên Windows, các phiên bản bị ảnh hưởng gồm Microsoft 365 Apps for Enterprise (các bản có số hiệu build thấp hơn 16.0.20326.20138), Office 2016 (thấp hơn build 16.0.5569.1000), Office 2019 (thấp hơn build 16.0.10417.20207), Office LTSC 2021 (thấp hơn build 16.0.14334.20906) và Office LTSC 2024 (thấp hơn build 16.0.17932.20976). Trên macOS, các phiên bản Office 365 for Mac, Office LTSC for Mac 2021 và Office LTSC for Mac 2024 cũng bị ảnh hưởng nếu chưa đạt build 16.113.26091433.

- Khuyến nghị: Cập nhật bản vá bảo mật chính thức do Microsoft phát hành theo hướng dẫn tại địa chỉ: https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-78505. Bật chế độ Protected View để kiểm soát các tệp nhận từ nguồn bên ngoài và các vị trí mạng không đáng tin cậy. Đồng thời, cấu hình hệ thống bảo mật thư điện tử (Email Gateway) để quét và cách ly các tệp Office đính kèm có nguồn gốc từ bên ngoài tổ chức trước khi cho phép người dùng mở.

2. Lỗ hổng bảo mật phần mềm trên hệ điều hành Linux

Lỗ hổng CVE-2026-87886 - Trong thiết lập quyền hạn tệp tin sao lưu đám mây của Acronis trên máy chủ Linux

- Đánh giá mức độ nghiêm trọng: Cao; Điểm CVSS: 7.8/10.

- Mô tả: Lỗ hổng leo thang đặc quyền cục bộ xảy ra do việc thiết lập quyền đối với tệp không an toàn theo mặc định. Bằng cách lợi dụng các tệp của plugin được cấu hình quyền truy cập không chặt chẽ, tin tặc có thể thực thi các lệnh trái phép mà không cần sự tương tác của người dùng. Lỗ hổng cho phép tin tặc nâng quyền lên mức cao nhất (root), dẫn đến nguy cơ chiếm toàn quyền kiểm soát máy chủ lưu trữ (hosting server), can thiệp vào hạ tầng sao lưu và làm rò rỉ hoặc phá hủy dữ liệu.

- Phiên bản ảnh hưởng: Lỗ hổng ảnh hưởng đến Acronis Backup plugin cho cPanel & WHM (Linux) ở các bản dựng thấp hơn 1.9.3.1021; Acronis Backup extension cho Plesk (Linux) ở các bản dựng thấp hơn 1.8.11.638; và Acronis Backup plugin cho DirectAdmin (Linux) ở các bản dựng thấp hơn 1.2.3.238.

- Khuyến nghị: Theo thông báo của nhà phát hành, lỗ hổng đã bị khai thác dưới dạng lỗ hổng zero-day trước khi có bản vá. Quản trị viên hệ thống cần cập nhật ngay các thành phần tích hợp Acronis lên phiên bản đã khắc phục lỗ hổng. Đồng thời, cần kiểm kê toàn bộ máy chủ Linux đang sử dụng các thành phần tích hợp của Acronis. Do lỗ hổng liên quan đến hạ tầng sao lưu có mức độ nguy hiểm cao, quản trị viên nên rà soát nhật ký hệ thống (logs) để phát hiện dấu hiệu bất thường. Nếu phát hiện hệ thống đang chạy phiên bản bị ảnh hưởng, cần đánh giá nguy cơ xâm nhập và tiến hành kiểm tra an ninh phù hợp. Thông tin chi tiết về lỗ hổng: https://security-advisory.acronis.com/advisories/SEC-10986.

- Lỗ hổng chưa có PoC công khai.

3. Lỗ hổng bảo mật phần mềm trên tường lửa

Lỗ hổng CVE-2026-86131 - Chèn mã độc vào hệ điều hành Fireware OS cho phép thực thi mã từ xa

- Đánh giá mức độ nghiêm trọng: Nghiêm trọng; Điểm CVSS: 9.2/10.

- Mô tả: Lỗ hổng tiêm mã độc xảy ra trong quá trình xử lý cấu hình máy khách trên hệ điều hành WatchGuard Fireware OS. Lỗ hổng có thể bị khai thác hoàn toàn từ xa qua mạng mà không cần xác thực hoặc bất kỳ sự tương tác nào của người dùng. Tin tặc có thể gửi cấu hình độc hại đến thiết bị Firebox đang kết nối, từ đó thực thi các lệnh tùy ý với quyền root trên thiết bị bị ảnh hưởng, tạo điều kiện cho việc xâm nhập sâu hơn vào mạng nội bộ.

- Phiên bản ảnh hưởng: Lỗ hổng ảnh hưởng đến các phiên bản WatchGuard Fireware OS thuộc các nhánh sau: từ phiên bản 12.0 đến trước 12.5.21; từ phiên bản 12.12 đến trước 12.12.3; từ phiên bản 2025.0 đến trước 2026.2.3; và từ phiên bản 2026.3 đến trước 2026.3.2.

- Khuyến nghị: WatchGuard đã phát hành bản vá bảo mật. Quản trị viên cần nâng cấp thiết bị Firebox lên phiên bản an toàn tương ứng. Nếu chưa thể cập nhật phần mềm ngay, cần áp dụng các biện pháp giảm thiểu rủi ro phù hợp, như giới hạn quyền truy cập mạng vào dịch vụ bị ảnh hưởng, triển khai các lớp xác thực bổ sung hoặc cấu hình quy tắc trên tường lửa ứng dụng web (WAF) nếu phù hợp với cơ chế khai thác của lỗ hổng. Thông tin chi tiết: https://psirt.watchguard.com/CVE-2026-86131.

- Lỗ hổng chưa có PoC công khai.

4. Lỗ hổng bảo mật phần mềm trên dịch vụ web

Lỗ hổng CVE-2026-85097 – Cho phép tải lên tệp tin tùy ý không cần xác thực trong chức năng Pro Forms của plugin Bricksforge trên nền tảng WordPress.

- Đánh giá mức độ nghiêm trọng: Nghiêm trọng; Điểm CVSS: 9.8/10.

- Mô tả: Lỗ hổng bắt nguồn từ việc hệ thống tin tưởng dữ liệu do máy khách cung cấp (*trust the client*) mà không xác thực đầy đủ trường dữ liệu url do người dùng kiểm soát, nằm trong tham số temporaryFileUploads khi gửi biểu mẫu. Tin tặc có thể lấy mã nonce hợp lệ, tải lên một tệp đa định dạng (GIF/PHP polyglot) vượt qua bộ lọc MIME, sau đó điều chỉnh tham số gửi lên để khiến máy chủ xử lý tệp dưới dạng tệp PHP (.php). Khai thác thành công lỗ hổng có thể cho phép tin tặc thực thi mã PHP tùy ý, cài đặt web shell hoặc đánh cắp dữ liệu nhạy cảm.

- Phiên bản ảnh hưởng: Lỗ hổng ảnh hưởng đến các phiên bản Bricksforge từ 3.1.8.9 trở về trước.

- Khuyến nghị: Nhà phát hành đã phát hành bản vá bảo mật để khắc phục lỗ hổng. Quản trị viên hệ thống cần khẩn trương kiểm tra phiên bản plugin Bricksforge đang sử dụng và nâng cấp lên phiên bản đã khắc phục lỗ hổng. Sau khi cập nhật, nên rà soát các tệp được tải lên và nhật ký máy chủ để phát hiện dấu

hiệu khai thác đáng ngờ. Thông tin chi tiết: https://bricksforge.io/version-changelog/.

- Lỗ hổng có PoC: https://github.com//Wayang1337//CVE-2026-85097.

5. Lỗ hổng bảo mật phần mềm trên dịch vụ email

Lỗ hổng CVE-2026-96940 - Cho phép đọc hộp thư của người dùng khác trên Microsott Exchange Server

- Đánh giá mức độ nghiêm trọng: Cao; Điểm CVSS: 9.8/10.

- Mô tả: Lỗ hổng bắt nguồn từ cơ chế phân quyền không đầy đủ trong Microsoft Exchange Server. Theo Microsoft, tin tặc có thể lợi dụng lỗ hổng để nâng quyền, từ đó truy cập hộp thư của người dùng khác và đọc email, tệp đính kèm. Lỗ hổng không cho phép truy cập giữa các tenant khác nhau.

- Phiên bản ảnh hưởng: Lỗ hổng ảnh hưởng đến các phiên bản: Microsoft Exchange Server Subscription Edition RTM; Microsoft Exchange Server 2016 CU23; Microsoft Exchange Server 2019 CU14 và Microsoft Exchange Server 2019 CU15.

- Khuyến nghị: Microsoft đã triển khai biện pháp xử lý phía máy chủ đối với Exchange Online. Do đó, người dùng Exchange Online không cần thực hiện thêm hành động để khắc phục lỗ hổng này. Đối với các hệ thống Exchange Server tại chỗ, quản trị viên cần triển khai các bản cập nhật bảo mật được Microsoft phát hành ngày 02/10/2026. Trong đó, bản cập nhật KB5129957 dành cho Exchange Server 2019 CU14 và KB5129955 dành cho Exchange Server Subscription Edition. Thông tin chi tiết: https://msrc.microsoft.com/update-guide/en-US/advisory/CVE-2026-96940.

- Lỗ hổng có PoC: https://github.com//HQRKimhab//CVE-2026-96940.

6. Lỗ hổng bảo mật phần mềm trên ngôn ngữ lập trình

Lỗ hổng CVE-2026-109618 - Thực thi mã từ xa do lỗi hỏng bộ nhớ core của ngôn ngữ PHP

- Đánh giá mức độ nghiêm trọng: Nghiêm trọng; Điểm CVSS: 9.2/10.

- Mô tả: Lỗ hổng xảy ra trong quá trình PHP phân tích cú pháp yêu cầu (request parsing). Cụ thể, khi cơ chế quản lý giới hạn bộ nhớ của PHP gặp lỗi cạn kiệt bộ nhớ (Out-Of-Memory – OOM), hệ thống sử dụng hàm longjmp() để xử lý lỗi. Tuy nhiên, luồng điều khiển (control flow) không chuẩn khiến một số trạng thái dữ liệu của request chỉ được khởi tạo một phần (chưa được hoàn tác hoàn toàn). Quy trình dọn dẹp sau đó lại coi vùng bộ nhớ chưa được khởi tạo này là hợp lệ, dẫn đến lỗi hỏng bộ nhớ. Tin tặc có thể gửi các HTTP request được tùy

biến đặc biệt để kích hoạt OOM và khai thác lỗ hổng. Qua đó, tin tặc có thể cài đặt cửa hậu (backdoor), chiếm quyền kiểm soát máy chủ hoặc rò rỉ dữ liệu.

- Phiên bản ảnh hưởng: Lỗ hổng ảnh hưởng đến các phiên bản PHP, từ những nhánh cũ (bao gồm PHP 5.x và 7.x) đến các phiên bản thấp hơn 8.2.35, 8.3.36, 8.4.27 và 8.5.12.

- Khuyến nghị: PHP đã phát hành các bản vá khẩn cấp. Quản trị viên hệ thống cần nâng cấp PHP lên các phiên bản an toàn. Nhà phát hành nhấn mạnh rằng không có thay đổi cấu hình nào có thể giảm thiểu triệt để lỗ hổng này; biện pháp khắc phục cần thiết là áp dụng bản vá. Trong trường hợp chưa thể vá ngay, giải pháp tạm thời là chuyển hệ thống sang chế độ cách ly hoặc sử dụng tường lửa ứng dụng web (WAF) tại lớp biên để chặn các chuỗi request bất thường. Thông tin chi tiết: https://www.openwall.com/lists/oss-security/2026/10/21/6.

- Lỗ hổng có PoC: https://github.com//corelight//php2shell-detect.

7. Lỗ hổng bảo mật phần mềm trên trình duyệt

Lỗ hổng CVE-2026-102331 - Tràn bộ nhớ đệm vùng Heap trong Angle trên Google Chrome

- Đánh giá mức độ nghiêm trọng: Nghiêm trọng; Điểm CVSS: 9.6/10.

- Mô tả: Lỗ hổng tràn bộ nhớ đệm vùng Heap (Heap-based Buffer Overflow) xảy ra bên trong thành phần ANGLE (Almost Native Graphics Engine) của trình duyệt. Tin tặc khai thác lỗ hổng bằng cách lừa người dùng truy cập vào một trang HTML tùy chỉnh, khi đó lỗi tràn bộ nhớ đệm sẽ xảy ra cho phép tin tặc thực thi mã từ xa bên ngoài sandbox của trình duyệt.

- Phiên bản ảnh hưởng: Lỗ hổng này ảnh hưởng đến tất cả các phiên bản Google Chrome trên Android phiên bản trước 154.0.8037.92.

- Khuyến nghị: Google đã chính thức phát hành bản vá bảo mật cho lỗ hổng này. Vì vậy, người dùng Android cần cập nhật ứng dụng Google Chrome lên phiên bản 154.0.8037.92 hoặc mới hơn càng sớm càng tốt. Thông tin chi tiết: https://chromereleases.googleblog.com/2026/09/stable-channel-update-for-desktop_01807488085.html.

- Lỗ hổng chưa có PoC công khai.

8. Lỗ hổng bảo mật trên các thiết bị router Ruijie

8.1. Lỗ hổng CVE-2026-92398 - Chèn lệnh (Command Injection) trên thiết bị Ruijie

- Đánh giá mức độ nghiêm trọng: Nghiêm trọng; Điểm CVSS: 9.1/10.

- Mô tả:

+ Lỗ hổng thuộc loại chèn lệnh (Command Injection – CWE-77), xuất phát từ việc module quản lý danh sách thiết bị trong tính năng kiểm soát trẻ em (Parental Control) của router, cụ thể tại tệp usr/local/lua/dev_config/user_list_note.lua. Tham số name được truyền trực tiếp vào lệnh thực thi của hệ điều hành thông qua hàm os.execute() mà không trải qua bất kỳ bước lọc hoặc kiểm tra ký tự đặc biệt nào. Khi kẻ tấn công chèn các ký tự điều khiển shell vào trường này, firmware sẽ hiểu và thực thi phần lệnh được chèn thêm như một lệnh hệ thống hợp lệ, với quyền cao nhất là root.

+ Kẻ tấn công cần có tài khoản quản trị của thiết bị thông qua việc khai thác mật khẩu mặc định chưa được thay đổi, mật khẩu yếu hoặc thông tin đăng nhập bị lộ lọt từ trước. Sau khi có phiên đăng nhập hợp lệ, kẻ tấn công thực hiện hai thao tác liên tiếp: trước tiên, đăng ký một địa chỉ MAC giả vào danh sách kiểm soát trẻ em thông qua API hợp lệ của router; tiếp theo, gửi yêu cầu cập nhật tên thiết bị với trường name chứa mã lệnh độc hại (payload) nhằm thiết lập kết nối ngược (reverse shell) đến máy chủ của kẻ tấn công. Toàn bộ quá trình được thực hiện thông qua hai yêu cầu HTTP, không cần sử dụng công cụ đặc biệt.

+ Sau khi chiếm được quyền truy cập shell với đặc quyền root trên thiết bị, kẻ tấn công có thể đọc toàn bộ cấu hình mạng, trích xuất mật khẩu được lưu trữ trong bộ nhớ thiết bị, cài đặt cửa hậu (backdoor) tồn tại qua các lần khởi động lại và sử dụng router làm điểm trung chuyển để tấn công các thiết bị khác trong mạng nội bộ. Ngoài ra, kẻ tấn công có thể thay đổi cấu hình DNS nhằm chuyển hướng toàn bộ lưu lượng truy cập của người dùng đến các trang web giả mạo hoặc kích hoạt chế độ nghe lén để thu thập thông tin đăng nhập của các thiết bị có lưu lượng đi qua router.

- Phiên bản ảnh hưởng: Router Wi-Fi 6 Ruijie Reyee RG-EW3000GX sử dụng firmware phiên bản EW_3.0(1)B11P380. Lỗ hổng có thể bị khai thác từ xa qua mạng, không yêu cầu người dùng thực hiện thao tác và cho phép kẻ tấn công kiểm soát hoàn toàn thiết bị sau khi chiếm được tài khoản quản trị.

- Khuyến nghị: Cập nhật firmware lên phiên bản mới nhất do nhà sản xuất phát hành tại địa chỉ https://www.ruijienetworks.com/support và thay đổi mật khẩu quản trị sang mật khẩu có độ phức tạp cao. Đồng thời, cần cách ly giao diện quản lý router khỏi khả năng truy cập từ Internet, chỉ cho phép kết nối từ mạng quản trị nội bộ. Tắt tính năng kiểm soát trẻ em (Parental Control) nếu đơn vị không có nhu cầu sử dụng.

8.2. Lỗ hổng CVE-2026-92397 chèn lệnh (Command Injection) trên thiết bị Ruijie

- Đánh giá mức độ nghiêm trọng: Nghiêm trọng; Điểm CVSS: 9.1/10.

- Mô tả:

+ Lỗ hổng thuộc loại chèn lệnh (Command Injection – CWE-77), nằm tại hàm cc_set trong tệp nhị phân unifyframe-sgi.elf, thuộc module configChange – thành phần xử lý các thay đổi cấu hình của router. Tham số data.url được truyền vào hàm này và ghép trực tiếp vào lệnh shell mà không qua bước lọc hoặc kiểm tra dữ liệu đầu vào, dẫn đến khả năng thực thi lệnh tùy ý với quyền root thông qua cơ chế tương tự CVE-2026-92398. Điểm khác biệt so với CVE-2026-92398 là lỗ hổng này nằm trong tệp nhị phân đã được biên dịch sẵn (ELF binary) thay vì script Lua, khiến việc phát hiện và khắc phục thủ công trở nên khó khăn hơn.

+ Kẻ tấn công cần có tài khoản quản trị hợp lệ, sau đó gửi yêu cầu HTTP đến endpoint cấu hình của router với trường data.url chứa mã lệnh độc hại (payload) nhằm khai thác lỗ hổng. Hàm cc_set tiếp nhận tham số, ghép vào chuỗi lệnh hệ thống và thực thi trong cùng một quy trình. Khi khai thác thành công, kẻ tấn công có thể chiếm quyền truy cập shell với đặc quyền root, qua đó kiểm soát hoàn toàn thiết bị và mạng nội bộ phía sau router. Đáng chú ý, do lỗ hổng nằm trong module xử lý cấu hình (configChange), kẻ tấn công có thể can thiệp trực tiếp vào quá trình thay đổi cấu hình thiết bị như ghi đè cấu hình, vô hiệu hóa tường lửa hoặc mở các cổng dịch vụ ẩn mà người quản trị không hay biết.

- Phiên bản ảnh hưởng: Router Wi-Fi 6 Ruijie Reyee RG-EW3000GX sử dụng firmware phiên bản EW_3.0(1)B11P380. Lỗ hổng có thể bị khai thác từ xa qua mạng, không yêu cầu người dùng thực hiện thao tác và cho phép kẻ tấn công kiểm soát hoàn toàn thiết bị sau khi chiếm được tài khoản quản trị.

- Khuyến nghị: Cập nhật firmware lên phiên bản mới nhất do nhà sản xuất phát hành tại địa chỉ https://www.ruijienetworks.com/support; thay đổi mật khẩu quản trị sang mật khẩu có độ phức tạp cao; cách ly giao diện quản lý khỏi khả năng truy cập từ Internet; giám sát lưu lượng mạng bất thường phát sinh từ thiết bị và thường xuyên theo dõi các thay đổi cấu hình không được phép, đặc biệt đối với module configChange.

9. Lỗ hổng trên các thiết bị tường lửa Cisco

9.1. Lỗ hổng CVE-2026-76460 - Vượt qua xác thực (Authentication Bypass) trong Cisco Identity Services Engine (ISE)

- Đánh giá mức độ nghiêm trọng: Nghiêm trọng; Điểm CVSS: 10/10.

- Mô tả: Lỗ hổng tồn tại trong một API của Cisco Identity Services Engine (ISE) do kiểm soát xác thực không đầy đủ tại một điểm cuối API. Kẻ tấn công có thể gửi các yêu cầu được chế tạo đặc biệt tới API bị ảnh hưởng để bỏ qua cơ chế xác thực (Authentication Bypass). Nếu khai thác thành công, đối tượng tấn công có thể truy cập trái phép vào thiết bị thông qua giao diện quản trị web mà không cần thông tin đăng nhập hợp lệ.

- Phiên bản ảnh hưởng: Cisco Identity Services Engine (ISE) và Cisco ISE Passive Identity Connector (ISE-PIC) từ nhánh 3.1.0 đến 3.5.0

- Khuyến nghị: Khẩn trương cập nhật bản vá/phần mềm do Cisco phát hành để khắc phục lỗ hổng.

9.2. Lỗ hổng CVE-2026-76504 vượt qua xác thực (Authentication Bypass) trong hệ thống quản lý tập trung hạ tầng Cisco Catalyst SD-WAN Manager

- Đánh giá mức độ nghiêm trọng: Nghiêm trọng; Điểm CVSS: 9.8/10.

- Mô tả: Lỗ hổng tồn tại trong cơ chế quản lý xác thực phiên làm việc (API session-based authentication) của Cisco Catalyst SD-WAN Manager. Nguyên nhân là việc xử lý URI Encoding/URL Encoding không đúng cách trong yêu cầu HTTP. Kẻ tấn công có thể gửi một yêu cầu HTTP được chế tạo đặc biệt để vượt qua (bypass) quy tắc xác thực bảo vệ một API nhạy cảm. Sau khi khai thác thành công, đối tượng tấn công có thể truy cập API với quyền quản trị viên (admin) mà không cần thông tin đăng nhập hợp lệ.

- Phiên bản ảnh hưởng: Cisco Catalyst SD-WAN Manager bị ảnh hưởng bất kể cấu hình triển khai. Các phiên bản bị ảnh hưởng bao gồm nhiều phiên bản trước khi được vá như: 20.9.x, 20.12.x, 20.15.x, 20.18.x, 26.1.x và 26.2.

- Khuyến nghị: Nâng cấp lên phiên bản đã được Cisco vá lỗi theo khuyến cáo của nhà sản xuất.

10. Các lỗ hổng bảo mật chuỗi cung ứng khác

10.1. Lỗ hổng CVE-2026-86950 - Ghi dữ liệu vượt giới hạn bộ nhớ trong bộ xử lý đồ họa CoreGraphics của Apple

- Đánh giá mức độ nghiêm trọng: Cao; Điểm CVSS: 8.8/10.

- Mô tả: Lỗ hổng này do lỗi ghi ngoài phạm vi bộ nhớ (out-of-bounds write) xảy ra bên trong framework kết xuất đồ họa CoreGraphics của Apple. Tin tặc có thể chèn mã độc vào một tệp tin hình ảnh hoặc tài liệu (như PDF, file đồ họa 2D). Khi thiết bị của người dùng xử lý hoặc hiển thị tệp tin độc hại này, lỗi tràn bộ nhớ đệm sẽ bị kích hoạt. Từ đó tin tặc có thể thực thi mã tùy ý để chiếm quyền kiểm soát thiết bị từ xa và cài đặt mã độc hoặc đánh cắp dữ liệu.

- Phiên bản ảnh hưởng: Lỗ hổng bảo mật này ảnh hưởng đến các phiên bản hệ điều hành iOS và iPadOS thấp hơn 26.7.1 và các phiên bản macOS thấp hơn 15.8.1 (nhánh Sequoia) và thấp hơn 26.7.1 (nhánh Tahoe).

- Khuyến nghị: Apple khuyến nghị người dùng phải cập nhật khẩn cấp các thiết bị của mình lên các phiên bản đã được vá lỗi. Không có biện pháp xử lý tạm thời do lỗ hổng nằm ở framework lõi xử lý đồ họa (tự động kích hoạt khi xem

trước hình ảnh/tài liệu trên trình duyệt, email hay tin nhắn). Thông tin chi tiết về bản cập nhật: https://support.apple.com/en-us/149226.

- Lỗ hổng có PoC: https://github.com//34zY//CVE-2026-86950.

10.2. Lỗ hổng CVE-2026-92370 – Bỏ qua kiểm soát phiên truy cập từ xa trên TeamViewer

- Đánh giá mức độ nghiêm trọng: Cao; Điểm CVSS: 8.8/10.

- Mô tả: Lỗ hổng kiểm soát truy cập không nghiêm ngặt xảy ra bên trong phần mềm kết nối máy tính từ xa TeamVievver. Tin tặc có thể tấn công bằng cách can thiệp và sửa đổi các tham số kiểm soát truy cập (access control parameters) trong quá trình thiết lập phiên kết nối. Khai thác lỗ hổng thành công cho phép tin tặc vượt qua các thiết lập phân quyền do người dùng cấu hình. Nhờ đó có thể thực thi mã từ xa trên hệ thống mục tiêu.

- Phiên bản ảnh hưởng: Lỗ hổng bảo mật này ảnh hưởng đến tất cả phiên bản TeamVievver trên các hệ điều hành Windows, Linux, macOS.

- Khuyến nghị: Nhà phát hành khuyến nghị người dùng cần cập nhật phần mềm ngay lập tức do lỗ hổng cho phép bỏ qua các quy tắc bảo mật được cấu hình thủ công. Nên cách giải quyết triệt để và an toàn nhất là kiểm tra và cập nhật ứng dụng trên máy tính (cả bản Client lẫn bản Host nhận kết nối) lên phiên bản mới nhất đã được nhà phát hành vá lỗi. Thông tin chi tiết bản cập nhật: https://www.teamviewer.com/en/resources/trust-center/security-bulletins/tv-2026-1010/?.

- Lỗ hổng chưa có PoC công khai.

10.3. Lỗ hổng CVE-2026-76824 - Trên nền tảng phân tích và giám sát dữ liệu Splunk Enterprise

- Đánh giá mức độ nghiêm trọng: Nghiêm trọng; Điểm CVSS: 9.8/10.

- Mô tả:

+ Lỗ hổng thuộc kiểu Improper Neutralization (CWE-707): Splunk Enterprise không bảo đảm hoặc bảo đảm không đúng việc dữ liệu đầu vào từ người dùng được kiểm tra và làm sạch đúng cách trước khi xử lý hoặc hiển thị. Về bản chất, đây là lỗi không lọc (neutralize) dữ liệu độc hại tại điểm tiếp nhận, khiến nội dung do kẻ tấn công kiểm soát được chuyển trực tiếp vào luồng xử lý nội bộ hoặc hiển thị trên giao diện mà không qua bước kiểm tra tính hợp lệ.

+ Kẻ tấn công không cần tài khoản hoặc điều kiện tiên quyết, mà chỉ cần gửi dữ liệu được tạo thủ công trực tiếp đến Splunk Enterprise qua mạng. Dữ liệu này không được lọc và được Splunk xử lý, tạo điều kiện để kẻ tấn công kiểm soát luồng xử lý nội bộ, đánh cắp phiên làm việc của người dùng đang đăng nhập hoặc thực

thi hành động tùy ý trong ngữ cảnh của hệ thống. Khi khai thác thành công, kẻ tấn công có thể đọc dữ liệu nhạy cảm trong Splunk (bao gồm nhật ký hệ thống, thông tin đăng nhập và dữ liệu giám sát), sửa đổi dữ liệu hoặc cấu hình, cũng như làm gián đoạn hoạt động của hệ thống. Nguy cơ đặc biệt nghiêm trọng trong môi trường bảo mật vì Splunk thường là nơi tập trung nhật ký của toàn bộ hạ tầng. Việc chiếm quyền kiểm soát Splunk có thể tạo điều kiện để kẻ tấn công xóa dấu vết của các cuộc tấn công khác đang diễn ra trong mạng. Trong môi trường sử dụng Splunk làm hệ thống SIEM, một cuộc khai thác thành công có thể cho phép kẻ tấn công can thiệp vào dữ liệu giám sát, xóa hoặc giả mạo cảnh báo, gây nhiễu hệ thống phát hiện.

- Phiên bản bị ảnh hưởng: Splunk Enterprise thuộc các nhánh sau: nhánh 9.4 trước phiên bản 9.4.15; nhánh 10.0 trước phiên bản 10.0.10; nhánh 10.2 trước phiên bản 10.2.7; và nhánh 10.4 trước phiên bản 10.4.3.

- Khuyến nghị: Nâng cấp Splunk Enterprise lên phiên bản đã khắc phục lỗ hổng tương ứng: 9.4.15, 10.0.10, 10.2.7 hoặc 10.4.3. Tham khảo hướng dẫn chính thức tại: https://advisory.splunk.com/advisories/SVD-2026-1002. Hạn chế quyền truy cập giao diện web Splunk từ mạng bên ngoài và các mạng không tin cậy; chỉ cho phép truy cập từ mạng quản trị nội bộ được kiểm soát. Tắt hoặc giới hạn tính năng cho phép nhập dữ liệu HTML thô trong dashboard tùy chỉnh nếu không có nhu cầu sử dụng. Bật chính sách HTTP Strict Content-Security Policy trong cấu hình bảo mật web của Splunk để hạn chế tác động nếu lỗ hổng bị khai thác.

10.4. Lỗ hổng CVE-2026-88771 - Thực thi mã từ xa (RCE) trên thiết bị cân bằng tải Citrix NetScaler ADC và NetScaler Gateway

- Đánh giá mức độ nghiêm trọng: Nghiêm trọng; Điểm CVSS: 9.5/10.

- Mô tả:

+ Lỗ hổng thuộc loại kiểm tra đầu vào không đúng (CWE-20 – Improper Input Validation). Thành phần xử lý các yêu cầu mạng đến của NetScaler ADC tiếp nhận dữ liệu từ bên ngoài mà không xác minh đầy đủ tính hợp lệ trước khi xử lý. Kẻ tấn công có thể gửi dữ liệu được tạo thủ công nhằm kiểm soát luồng xử lý và đưa lệnh tùy ý vào hệ thống.

+ Kẻ tấn công không cần tài khoản hoặc cấu hình đặc biệt trên thiết bị mục tiêu, mà chỉ cần có khả năng kết nối mạng đến thiết bị NetScaler và gửi yêu cầu được tạo thủ công. Việc NetScaler xử lý dữ liệu không hợp lệ có thể dẫn đến thực thi lệnh tùy ý với quyền của tiến trình NetScaler, qua đó cho phép kẻ tấn công thiết lập cơ chế duy trì quyền truy cập lâu dài thông qua web shell. Khi khai thác thành công, kẻ tấn công có thể thực thi mã tùy ý trên thiết bị NetScaler. Đây là thiết bị thường được triển khai tại vành đai mạng, đóng vai trò cổng kết nối cho lưu lượng VPN, xác thực và truy cập từ xa. Kẻ tấn công có thể sử dụng web shell để duy trì

quyền truy cập lâu dài, đồng thời cài đặt các công cụ tạo đường hầm (tunneling tools) nhằm vượt qua tường lửa, tạo điều kiện xâm nhập sâu hơn vào mạng nội bộ.

- Phiên bản bị ảnh hưởng: Citrix NetScaler ADC và NetScaler Gateway thuộc nhánh 14.1 trước bản build 14.1-73.37; nhánh 13.1 trước bản build 13.1-64.23; NetScaler ADC 14.1-FIPS trước bản build 14.1-73.37 FIPS; và NetScaler ADC 13.1-FIPS/NDcPP trước bản build 13.1-37.279.

- Khuyến nghị: Nâng cấp phần mềm lên bản build 14.1-73.46 hoặc mới hơn đối với nhánh 14.1, hoặc bản build 13.1-64.29 hoặc mới hơn đối với nhánh 13.1. Tham khảo hướng dẫn tại: https://support.citrix.com/external/article/CTX697096. Trong trường hợp chưa thể vá lỗi, cần hạn chế tối đa quyền truy cập mạng đến giao diện quản lý và mặt phẳng dữ liệu (data plane) của NetScaler.

Nhằm bảo đảm an ninh mạng đối với hệ thống thông tin các cơ quan Đảng, Nhà nước trên địa bàn tỉnh, Công an tỉnh đề nghị Thủ trưởng các cơ quan, đơn vị, địa phương tiếp tục chỉ đạo rà soát, kiểm tra các dịch vụ, phần mềm đang sử dụng, kịp thời cập nhật, vá lỗi hệ thống. Nếu phát hiện tồn tại các lỗ hổng trên thì thực hiện các biện pháp khắc phục theo khuyến nghị; đồng thời tiếp tục tăng cường triển khai các biện pháp giám sát liên tục các hệ thống thông tin, phát hiện sớm các dấu hiệu bất thường, tấn công mạng. Trong quá trình thực hiện nếu có khó khăn, vướng mắc kịp thời liên hệ Công an tỉnh *(qua Phòng An ninh mạng và phòng, chống tội phạm sử dụng công nghệ cao, số điện thoại 0966.833.937)* để được hỗ trợ.

Công an tỉnh trao đổi và đề nghị các cơ quan, đơn vị, địa phương phối hợp thực hiện./.

Nơi nhận:
- Như trên;
- UBND tỉnh (báo cáo);
- Đ/c Giám đốc Công an tỉnh (b/cáo);
- Phòng Tham mưu;
- Công an các xã, phường, đặc khu;
- Lưu: VT, ANM.

KT. GIÁM ĐỐC
PHÓ GIÁM ĐỐC

Đại tá Nguyễn Thành Long